



Politécnico
Internacional

FUNDAMENTOS EN CIBERSEGURIDAD

“Cualquier tecnología suficientemente avanzada es equivalente a la magia..”

Arthur C. Clarke

- ☐ Fundamentos de la seguridad
- ☐ Amenazas, Vulnerabilidades y Ataques
- ☐ Fases de un Ciberataque
- ☐ Malware: Definición y tipos
- ☐ Técnicas de Malware
- ☐ Perfiles de Atacantes y robo de identidad
- ☐ DDoS E Ingeniería Social
- ☐ Buenas Prácticas: Ciberseguridad
- ☐ Organizaciones de apoyo en Colombia
- ☐ Conclusiones

Seguridad de la información

La seguridad de la información es el conjunto de prácticas, políticas y controles diseñados para proteger la información, sin importar el formato en que se encuentre (físico o digital), contra accesos no autorizados, alteraciones, destrucción o divulgación. Su objetivo es garantizar los principios fundamentales de la confidencialidad, integridad y disponibilidad de los datos, asegurando que la información sea precisa, esté protegida y disponible cuando se necesite.



Seguridad Informática

La seguridad informática se enfoca en proteger los componentes tecnológicos — como hardware, software, redes y sistemas— que procesan y almacenan información. Incluye la implementación de herramientas y procedimientos para prevenir intrusiones, fallos, malware u otros riesgos que puedan afectar la operatividad de los sistemas. Su ámbito de acción se limita al entorno tecnológico.



Ciberseguridad

La ciberseguridad es la disciplina encargada de proteger los activos digitales que operan en entornos conectados, especialmente internet y redes privadas, frente a amenazas cibernéticas como ataques maliciosos, robo de datos, suplantación de identidad o sabotaje. Va más allá de los aspectos técnicos al incluir factores humanos, organizacionales y normativos, con el fin de crear un ecosistema digital seguro frente a riesgos en constante evolución.



TRIADA DE SEGURIDAD DE LA INFORMACION

TRIADA DE SEGURIDAD DE LA INFORMACION

La **tríada de la seguridad de la información**, también conocida como **tríada CIA**, está compuesta por tres principios fundamentales: **confidencialidad**, que garantiza que la información solo sea accesible por personas autorizadas; **integridad**, que asegura que los datos no sean modificados de forma no autorizada y se mantengan exactos y completos; y **disponibilidad**, que garantiza que la información y los sistemas estén accesibles cuando se necesiten. Estos tres elementos son la base de toda política de seguridad y trabajan en conjunto para proteger los activos de información frente a amenazas internas y externas.



TRIADA DE SEGURIDAD DE LA INFORMACION

La **disponibilidad** es uno de los pilares fundamentales de la seguridad de la información y se refiere a la capacidad de los sistemas, servicios y datos para estar accesibles y operativos en el momento en que se necesiten.

Esto implica garantizar que los usuarios autorizados puedan acceder a la información sin interrupciones, incluso ante fallos técnicos, ataques cibernéticos o desastres.

La disponibilidad se logra mediante mecanismos como redundancia, planes de respaldo, tolerancia a fallos y mantenimiento continuo de la infraestructura tecnológica.

TRIADA DE SEGURIDAD DE LA INFORMACION

Tríada CIA
Confidencialidad
Integridad
Disponibilidad



sealpath.

TRIADA DE SEGURIDAD DE LA INFORMACION

La **integridad** es un principio fundamental de la seguridad de la información que garantiza que los datos se mantengan exactos, completos y sin alteraciones no autorizadas durante su almacenamiento, procesamiento o transmisión.

Su objetivo es asegurar que la información no sea modificada de forma intencional o accidental por personas no autorizadas o por errores del sistema. Mantener la integridad implica implementar controles como el control de versiones, el uso de firmas digitales, sumas de verificación (**hash**) y restricciones de acceso..

TRIADA DE SEGURIDAD DE LA INFORMACION

Tríada CIA
Confidencialidad
Integridad
Disponibilidad



sealpath.

TRIADA DE SEGURIDAD DE LA INFORMACION

La **confidencialidad** es un principio esencial de la seguridad de la información que busca garantizar que los datos solo sean accesibles por personas, sistemas o procesos autorizados.

Su propósito es evitar la divulgación no autorizada de información sensible o privada, protegiendo así la privacidad y los secretos organizacionales. Para mantener la confidencialidad se emplean medidas como el cifrado de datos, controles de acceso, autenticación de usuarios y políticas de clasificación de la información.

TRIADA DE SEGURIDAD DE LA INFORMACION

Tríada CIA
Confidencialidad
Integridad
Disponibilidad



sealpath.

Una **amenaza** en ciberseguridad es cualquier evento, acción o condición potencial que puede explotar una vulnerabilidad en un sistema y causar daño, pérdida o acceso no autorizado a la información. Las amenazas pueden ser intencionales (como ataques de hackers), accidentales (errores humanos) o naturales (fallos eléctricos o desastres).

Ejemplo técnico:

Un atacante externo escanea una red corporativa en busca de puertos abiertos utilizando herramientas como **Nmap**. Esta actividad representa una amenaza, ya que podría detectar servicios vulnerables y posteriormente ejecutar un ataque para obtener acceso no autorizado.



VULNERABILIDADES EN CIBERSEGURIDAD

Una **vulnerabilidad** es una debilidad o falla en un sistema, aplicación, red o proceso que puede ser explotada por una amenaza para comprometer la seguridad de la información. Estas debilidades pueden ser causadas por errores de configuración, fallos de software, ausencia de parches de seguridad o prácticas inseguras por parte de los usuarios.

Ejemplo técnico:

Una aplicación web que no valida correctamente la entrada del usuario es vulnerable a un ataque de **inyección SQL**, lo que permite a un atacante ejecutar comandos maliciosos directamente en la base de datos y acceder a información confidencial.



Un **ataque** es una acción deliberada llevada a cabo por un actor malintencionado con el objetivo de explotar una vulnerabilidad en un sistema o red para comprometer su confidencialidad, integridad o disponibilidad. Los ataques pueden ser manuales o automatizados, y su finalidad puede ser el robo de información, sabotaje, interrupción de servicios o acceso no autorizado.

Ejemplo técnico:

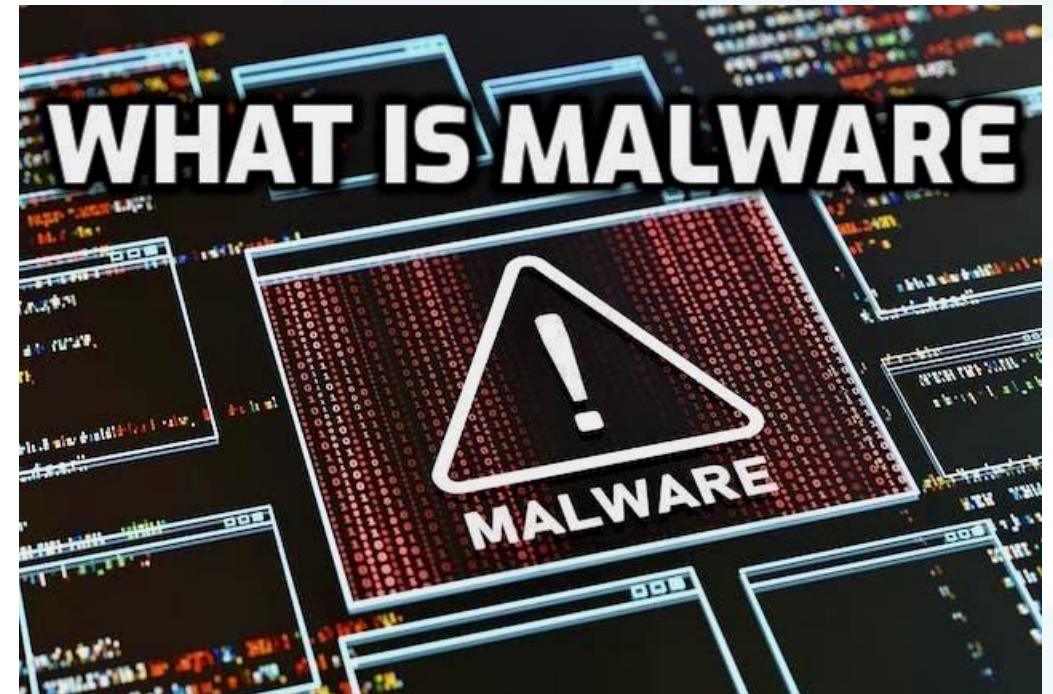
Un atacante aprovecha una vulnerabilidad sin parchear en un servidor web para ejecutar código remoto (**RCE**) y tomar el control del sistema, instalando un *backdoor* que le permite acceder de forma persistente y no autorizada.



El **malware** (abreviatura de *malicious software*) es cualquier tipo de software diseñado específicamente para dañar, infiltrarse o afectar el funcionamiento normal de sistemas, redes o dispositivos sin el consentimiento del usuario. Su objetivo puede ser robar información, espiar actividades, secuestrar recursos o causar interrupciones operativas.

Ejemplo técnico:

Un usuario descarga un archivo adjunto aparentemente legítimo desde un correo de phishing. Al ejecutarlo, se instala un **RANSOMWARE** que cifra todos los archivos del sistema y muestra una pantalla exigiendo un pago en criptomonedas para restaurar el acceso a la información.



TIPOS DE MALWARE

(CIBERSEGURIDAD)

Virus:

Código malicioso que se adhiere a archivos o programas legítimos y se replica al ejecutarlos. Requiere acción del usuario para activarse.

Ejemplo: Un archivo .exe infectado que al abrirse propaga el virus al sistema.

Gusano (Worm):

Malware autónomo que se replica automáticamente a través de redes, sin necesidad de intervención humana.

Ejemplo: El gusano **Blaster** explotaba vulnerabilidades en Windows para propagarse por red.



TIPOS DE MALWARE

(CIBERSEGURIDAD)

Troyano:

Se disfraza de software legítimo para engañar al usuario e instalar código malicioso. Abre puertas traseras para futuros ataques.

Ejemplo: Un supuesto "optimizador de PC" que instala un *backdoor* oculto.

Troyano SMS:

Versión de troyano orientada a dispositivos móviles, que envía mensajes de texto a números premium sin autorización.

Ejemplo: Apps falsas que suscriben al usuario a servicios pagos sin que lo note.



Ransomware:

Secuestra el sistema cifrando archivos y exige un rescate económico para restaurar el acceso.

Ejemplo: WannaCry cifró millones de archivos en empresas alrededor del mundo en 2017.

Backdoor (puerta trasera):

Permite al atacante acceder remotamente a un sistema comprometido, eludiendo mecanismos de seguridad.

Ejemplo: Un backdoor en un servidor que permite controlar el sistema vía comandos ocultos.



TIPOS DE MALWARE (CIBERSEGURIDAD)

Keylogger:

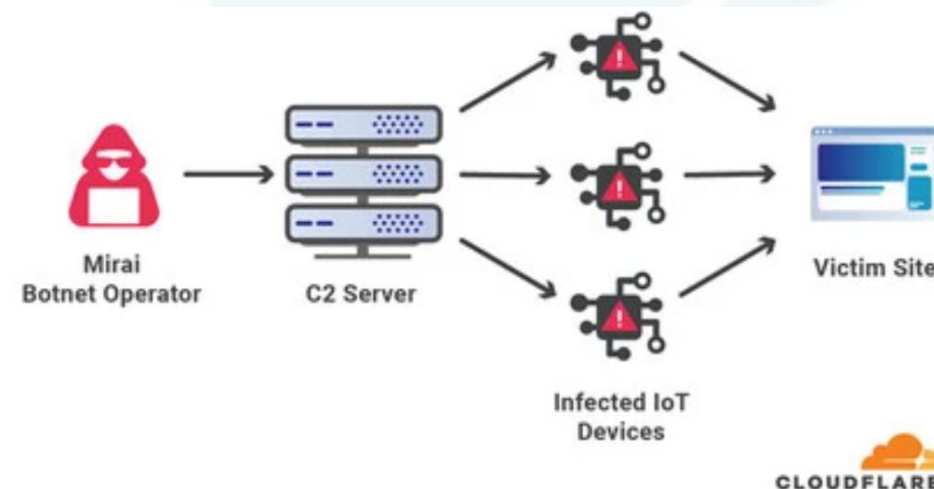
Registra las pulsaciones del teclado para capturar contraseñas, correos y otra información sensible.

Ejemplo: Se instala como parte de un troyano para robar credenciales bancarias.

Bot:

Dispositivo infectado que puede ser controlado remotamente como parte de una red (botnet), usada para ataques coordinados.

Ejemplo: Usado en ataques DDoS masivos como el de Mirai.



TIPOS DE MALWARE

(CIBERSEGURIDAD)

Scammer (software de estafa):

Programas diseñados para engañar al usuario y obtener dinero mediante fraude.

Ejemplo: Falsos antivirus que alertan sobre infecciones inexistentes y piden pago para "limpiar" el sistema.

Adware:

Muestra anuncios no deseados, recolecta datos del usuario y puede ralentizar el sistema.

Ejemplo: Navegadores modificados para redirigir a páginas con publicidad intrusiva.

From: Netflix <rahma-cakupuyje-vakangenlaaywa@bihvgh.com>
Date: September 14, 2020 at 6:05:32 AM GMT+2
To: [REDACTED]
Subject: Re: Update Payment Subscription - We can't authorize payment September 13, 2020.
Order Number : 38443246

NETFLIX

Update current billing information

Hi,

Unfortunately, we cannot authorize your payment for the next billing cycle of your subscription, Netflix was unable to receive a payment because the financial institution rejected the monthly charge.

TRY AGAIN PAYMENT

Obviously we'd love to have you back. If you change your mind, simply restart your membership and update your payment to enjoy all the best TV shows & movies without interruption.

- Netflix Team

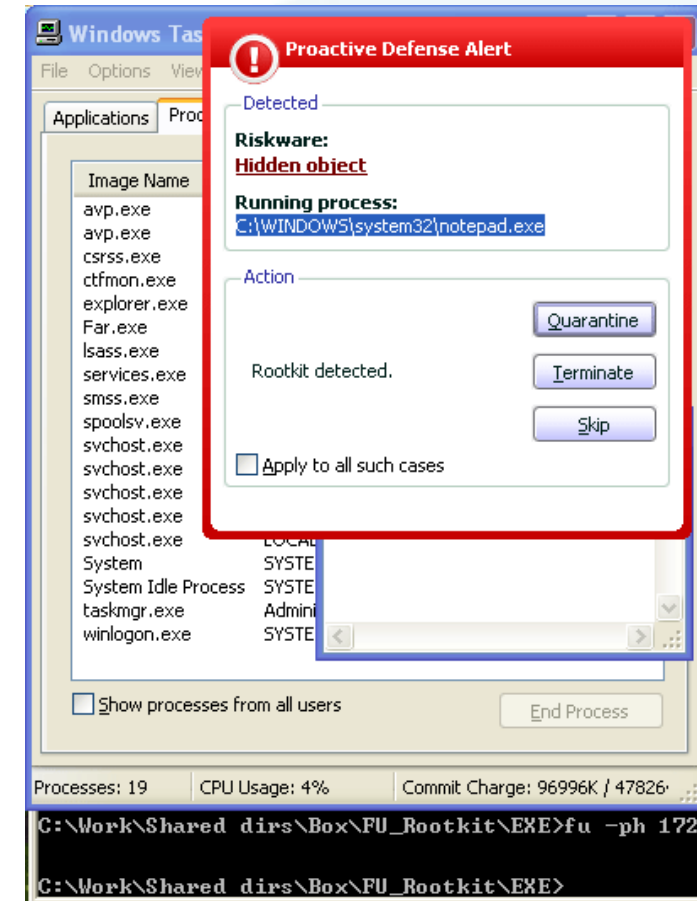
TIPOS DE MALWARE

(CIBERSEGURIDAD)

Rootkit:

Oculta otros tipos de malware al alterar el sistema operativo para evitar su detección.

Ejemplo: Un rootkit en el kernel que impide que los antivirus detecten procesos maliciosos activos.



TECNICAS DE MALWARE

(CIBERSEGURIDAD)

Exploit:

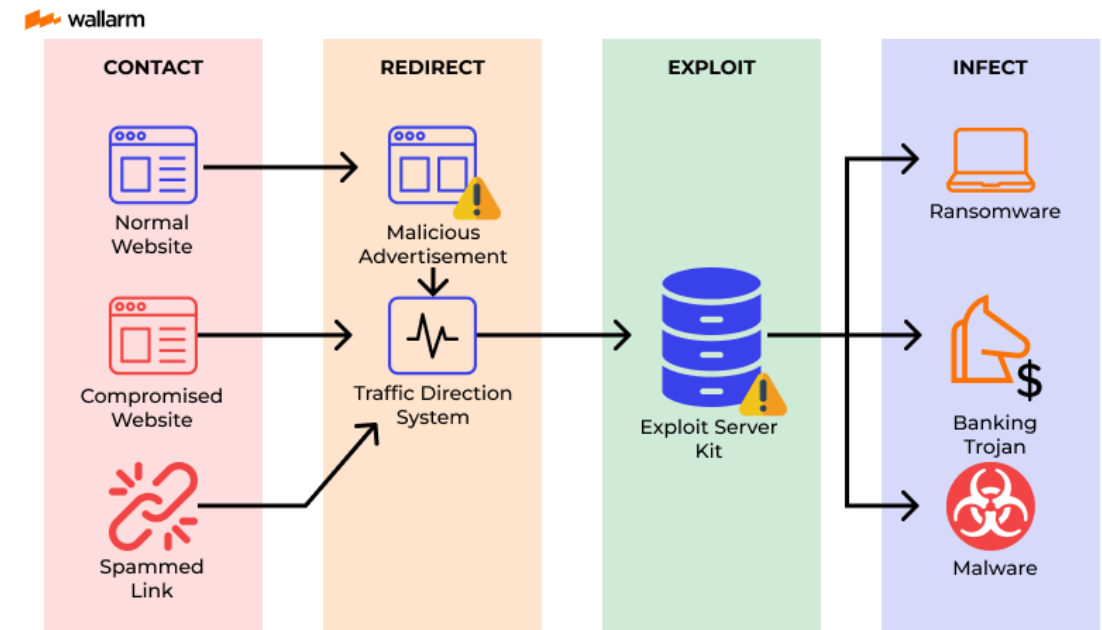
Aprovecha una vulnerabilidad en un software o sistema para ejecutar código malicioso sin autorización.

Ejemplo técnico: Un exploit en una versión desactualizada de Adobe Reader permite ejecutar código remoto al abrir un PDF malicioso.

Payload:

Es la “carga útil” del malware, es decir, la parte que ejecuta la acción dañina (como cifrar archivos, abrir una puerta trasera, etc.).

Ejemplo técnico: Un **ransomware** cuyo payload cifra el disco duro del usuario y luego muestra una nota de rescate.



TECNICAS DE MALWARE

(CIBERSEGURIDAD)

Ocultación (Obfuscation):

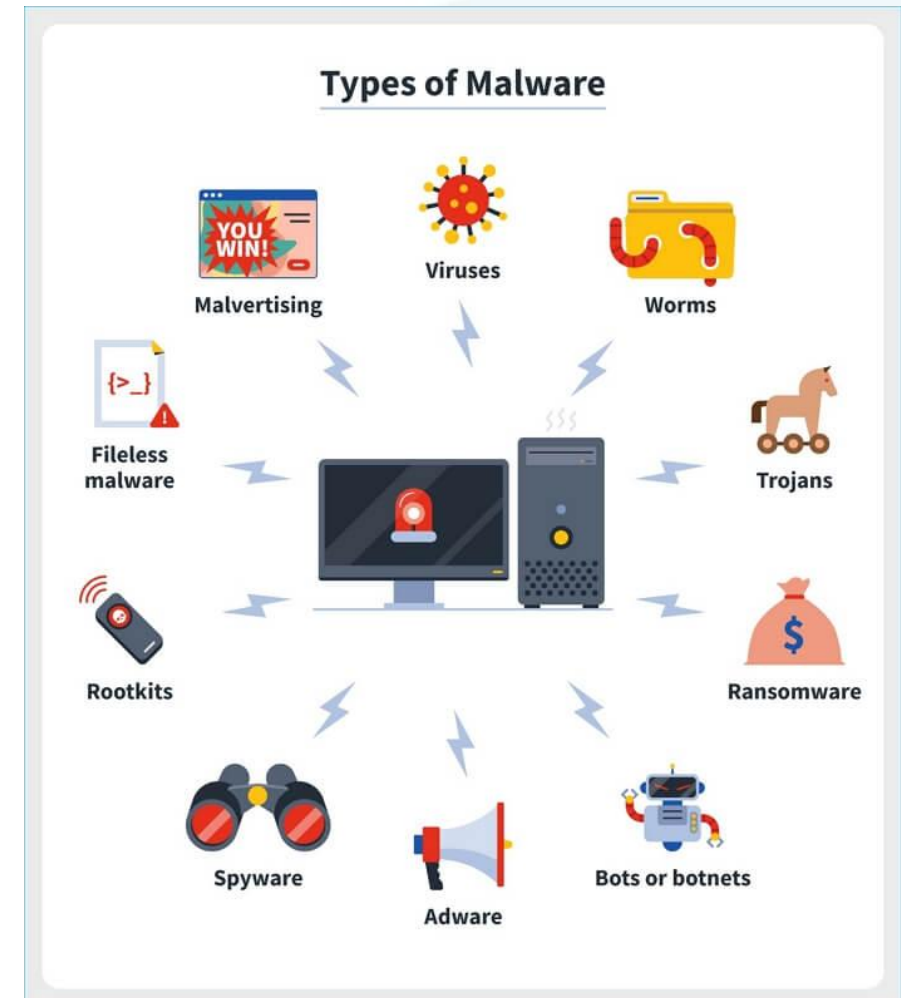
Técnica para esconder el código malicioso dentro del software, haciéndolo difícil de detectar o analizar.

Ejemplo técnico: Código JavaScript ofuscado en una página web para evadir filtros de seguridad.

Enmascaramiento (Masquerading):

El malware se hace pasar por una aplicación legítima o de confianza para engañar al usuario.

Ejemplo técnico: Un archivo llamado Factura2025.pdf.exe con icono de PDF que realmente es un ejecutable malicioso.



Ataques de evasión (Evasion):

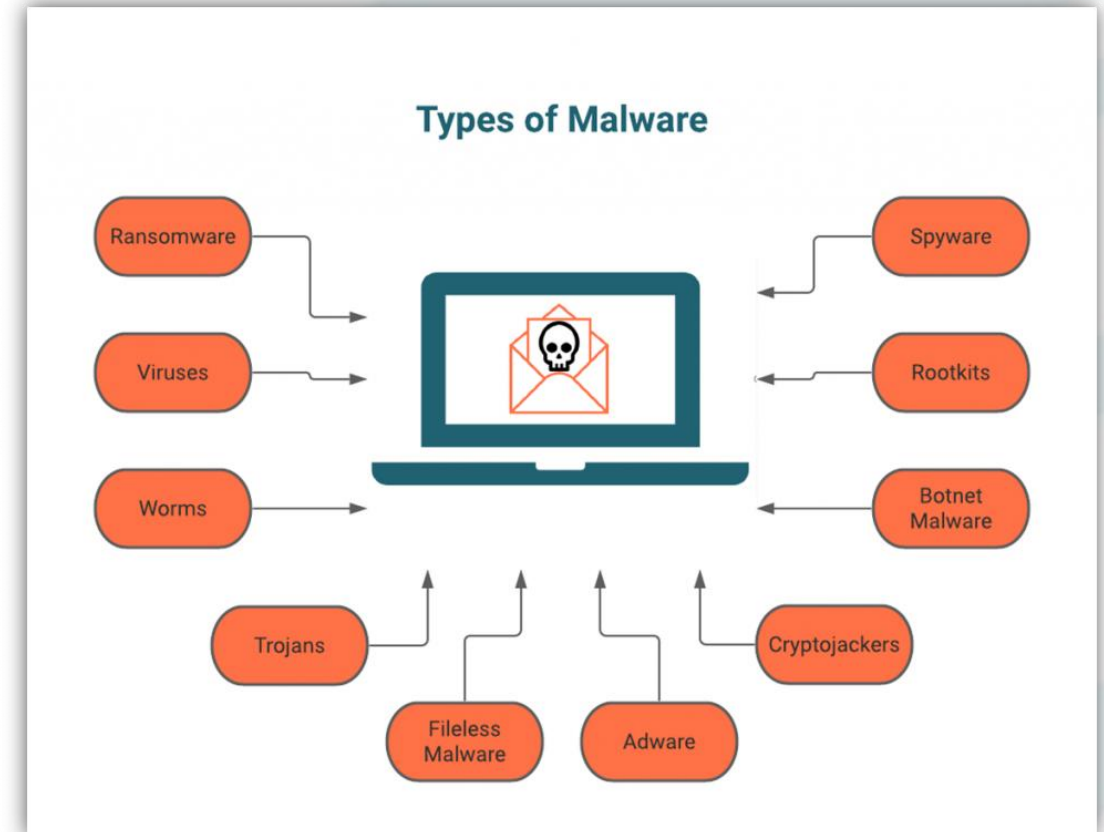
Tácticas usadas para evitar la detección por antivirus, firewalls o sistemas de monitoreo.

Ejemplo técnico: Un malware que detecta si está siendo ejecutado en un entorno virtual y no se activa hasta estar en un sistema real.

Escalada de privilegios:

Consiste en obtener niveles de acceso más altos dentro del sistema de forma ilegítima, para realizar acciones restringidas.

Ejemplo técnico: Un atacante que explota una vulnerabilidad del sistema para pasar de usuario estándar a administrador (root).



Atacantes profesionales:

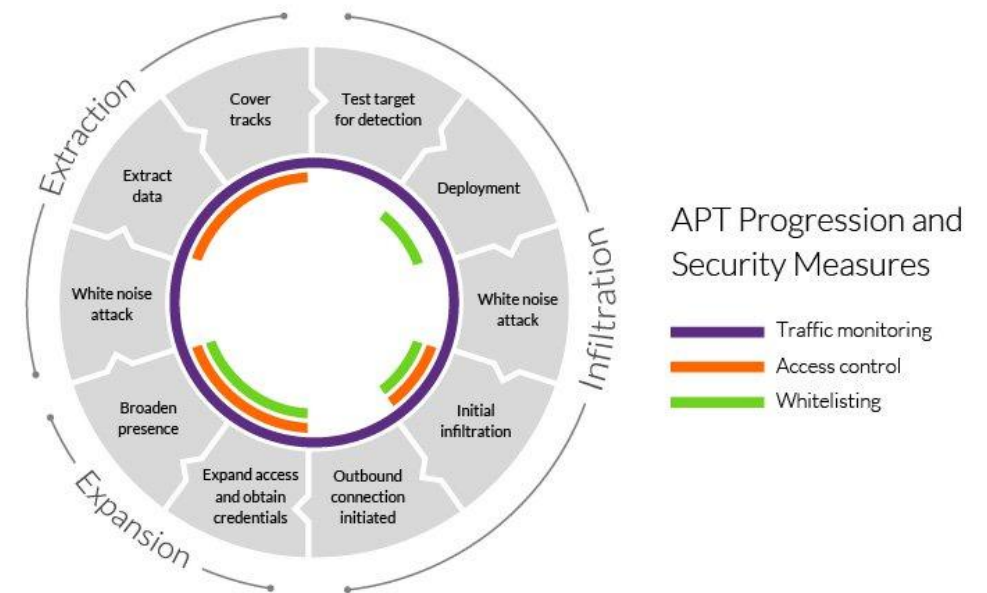
Son expertos con conocimientos avanzados en redes, sistemas y explotación de vulnerabilidades. Suelen trabajar para organizaciones delictivas o incluso gobiernos.

Ejemplo : Un grupo APT (Advanced Persistent Threat) que infiltra sistemas corporativos para espionaje industrial o sabotaje.

Ciberdelincuentes:

Buscan beneficios económicos mediante actividades ilegales como fraudes, extorsión, robo de datos o acceso a cuentas bancarias.

Ejemplo: Hackers que distribuyen ransomware para exigir pagos en criptomonedas.



Robo de Identidad

El robo de identidad es el acto de obtener y utilizar la información personal de un usuario sin su autorización, con el fin de suplantar su identidad para cometer fraudes o delitos. Esto puede incluir el uso de credenciales, documentos, números de tarjetas o accesos a cuentas.

Ejemplo técnico:

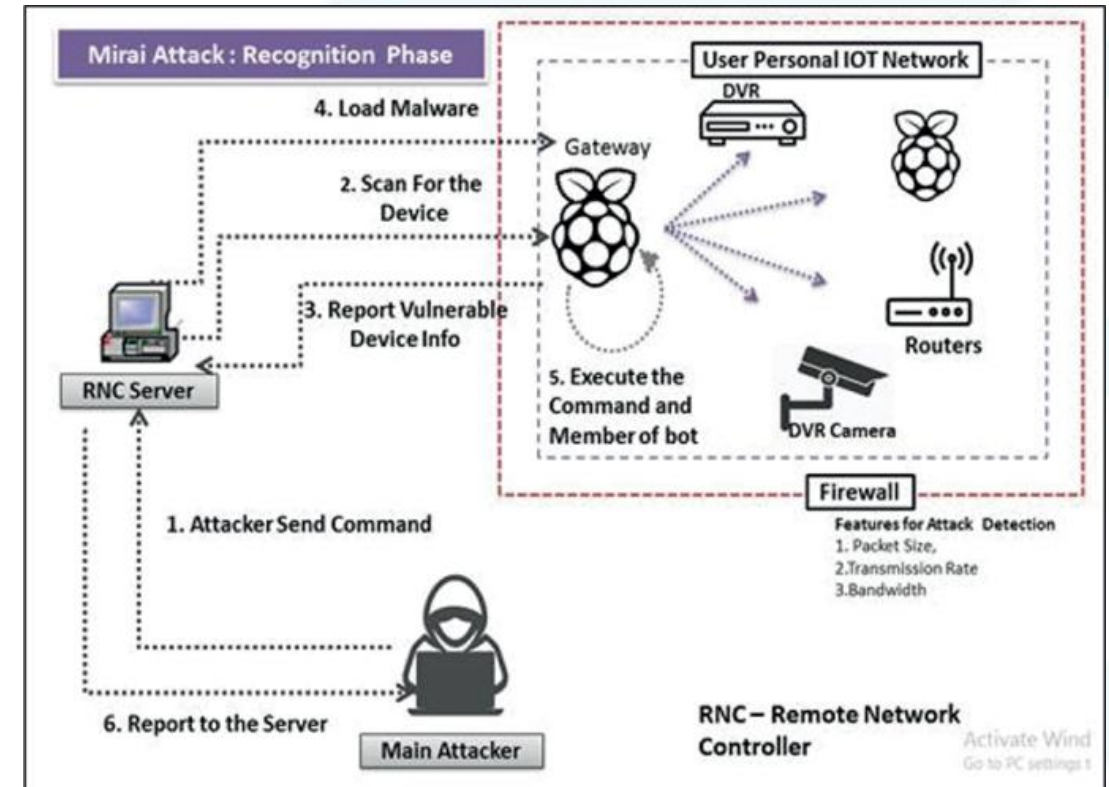
Un atacante usa un keylogger para capturar el usuario y contraseña del correo corporativo de una víctima. Luego, accede a su cuenta y envía mensajes maliciosos desde su identidad para obtener información confidencial de otros empleados o clientes (ataque de ingeniería social).



Denegación de Servicio Distribuida (DDoS)

Un ataque de Denegación de Servicio Distribuida (DDoS) consiste en saturar un servidor, red o aplicación con una gran cantidad de solicitudes maliciosas provenientes de múltiples dispositivos comprometidos (conocidos como bots), con el objetivo de interrumpir o bloquear el acceso a servicios legítimos. A diferencia de un ataque DoS tradicional, el DDoS se ejecuta desde múltiples puntos distribuidos, lo que lo hace más difícil de mitigar.

Ejemplo técnico: Un atacante controla una botnet de miles de dispositivos IoT infectados (como cámaras IP) y los utiliza para enviar millones de peticiones simultáneas al servidor web de una institución financiera, causando la caída de su sitio por varias horas. Este tipo de ataque fue similar al de **Mirai en 2016**, que afectó grandes servicios como Twitter, Netflix y Spotify.



Ingeniería Social

La **ingeniería social** es una técnica de manipulación psicológica utilizada por atacantes para engañar a las personas y hacer que revelen información confidencial, otorguen acceso no autorizado o realicen acciones perjudiciales. A diferencia de los ataques puramente técnicos, este tipo de amenaza se enfoca en explotar la **confianza humana**, el descuido o la falta de conocimiento en seguridad.

Ejemplo técnico: Un atacante envía un correo electrónico suplantando al departamento de TI de la empresa, solicitando con urgencia que el empleado actualice su contraseña a través de un enlace falso. Al ingresar sus credenciales, el atacante las captura y obtiene acceso al sistema corporativo. Este tipo de ataque se conoce como **phishing** y es una de las formas más comunes de ingeniería social.



Buenas Prácticas en Ciberseguridad

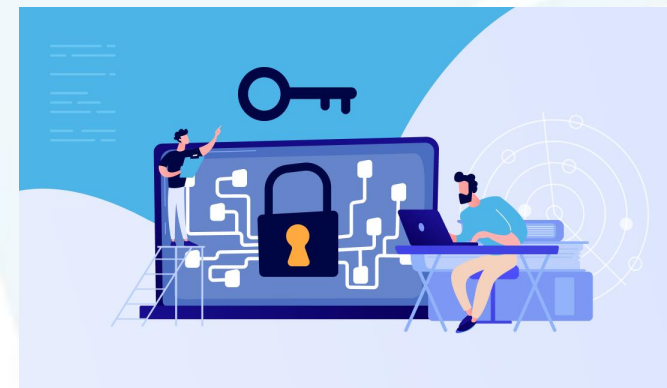
Las buenas prácticas en ciberseguridad son un conjunto de acciones preventivas y hábitos recomendados para proteger la información, los sistemas y las redes frente a amenazas y ataques digitales. Estas prácticas son fundamentales tanto a nivel individual como organizacional para reducir el riesgo de incidentes de seguridad.



Buenas Practicas

CIBERSEGURIDAD

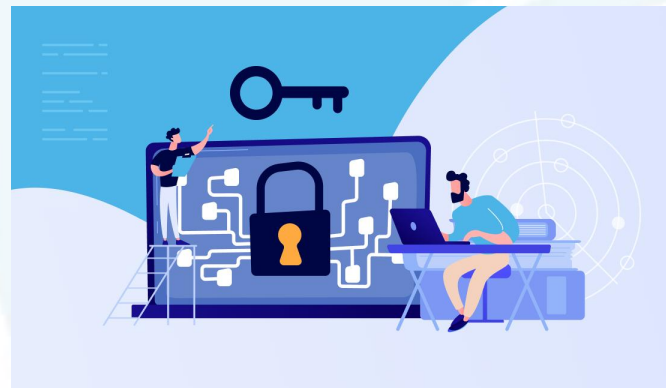
Buena Práctica	Descripción	Ejemplo Técnico
Contraseñas seguras	Crear contraseñas largas, complejas y únicas para cada servicio.	S3guridad#2025! en lugar de 123456
Autenticación multifactor (MFA)	Añadir una capa adicional de seguridad al iniciar sesión.	Ingreso de contraseña + código por app móvil (Google Authenticator, SMS, etc.)
Actualización de sistemas	Instalar parches de seguridad y actualizaciones de software regularmente.	Aplicar actualizaciones mensuales en Windows, navegadores y antivirus
Evitar correos sospechosos	No abrir enlaces o archivos de remitentes desconocidos.	Ignorar un correo que simula ser de un banco con un enlace fraudulento
Copias de seguridad (backups)	Realizar respaldos periódicos de información crítica.	Backup automático en la nube cada 7 días con cifrado
Restricción de privilegios	Asignar a cada usuario solo los permisos necesarios para su rol.	Un empleado de soporte no debe tener acceso como administrador del servidor
Capacitación en seguridad	Formar a los usuarios sobre riesgos y protocolos de protección.	Cursos o simulacros de phishing en la organización



Organizaciones de Apoyo en Colombia

CIBERSEGURIDAD

Organización	Función Principal	Enlace / Ejemplo de actividad
ColCERT (Centro Cibernético Policial)	Equipo nacional de respuesta a incidentes (CSIRT) para entidades públicas y privadas.	ColCERT – Servicios y contacto : gestiona incidentes, boletines y alertas de vulnerabilidad (gobiernodigital.mintic.gov.co , colcert.gov.co)
MinTIC (Ministerio de Tecnologías de la Información y las Comunicaciones)	Diseña políticas, estándares y promueve normativas como el Modelo de Seguridad y Privacidad (MSPI).	Res. 746 (2022) y MSPI en su micrositio de Seguridad Digital (Mintic , gobiernodigital.mintic.gov.co)
Grupo de Respuesta a Emergencias Cibernéticas del Gobierno (CSIRT Gobierno)	Protege activos digitales estatales y coordina el SOC nacional.	SOC civil público inaugurado para gestionar amenazas nacionales (Mintic , Mintic)
CCIT (Cámara Colombiana de Informática y Telecomunicaciones)	Fortalece la transformación digital y fomenta la ciberseguridad empresarial.	Eventos como el Foro de Ciberseguridad para empresas en Colombia (info en su web)
AndinaCERT	CSIRT regional asociado a FIRST, apoya en respuesta técnica a incidentes y malware.	Colabora con universidades y organizaciones en análisis de amenazas
Colnodo	Promueve la educación digital y seguridad, con enfoque en derechos digitales.	Miembro de CiviCERT y ACLAC, ofrece cursos de seguridad para la ciudadanía (es.wikipedia.org)



CONCLUSIONES